Podręcznik administratora TestGEN

Spis treści

- Podręcznik administratora — indeks
  - Dokumenty
  - Powiązane
- Podręcznik administratora TestGEN
  - Spis treści
  - 1. Wprowadzenie
  - 2. Zarządzanie tenantami (firmami)
  - 3. Zarządzanie użytkownikami
  - 4. Macierz uprawnień (RBAC)
  - 5. Zarządzanie planami i rozliczeniami
  - 6. Monitoring i logi
  - 7. Konfiguracja trybu silnika (engine_mode)
  - 8. Zarządzanie kluczami API
  - 9. Dziennik audytu (Audit Trail)
  - 10. Kopie zapasowe i przywracanie danych
  - 11. Aktualizacje systemu
  - 12. Pipeline CVE
  - Dodatek A: Szybka ściągawka administratora
  - Dodatek B: Słownik terminów
- Panel administracyjny
  - 1. Dostęp i architektura
  - 2. Użytkownicy
  - 3. Firmy (tenanci)
  - 4. Dziennik audytu
  - 5. Konfiguracja platformy
  - 6. Pipeline CVE
  - 7. Zdrowie webhooków płatności
  - 8. Zasady i dostępność

Podręcznik administratora — indeks

> Operacje administratora platformy (rola **Admin** — globalna, poza hierarchią firm/tenantów).

Dokumenty

Dokument	Zakres
admin-guide.md	**Kompletny podręcznik administratora:** zarządzanie firmami (tenantami), użytkownikami, RBAC, plany i rozliczenia, monitoring (Grafana/Loki), tryb silnika, klucze API, dziennik audytu, kopie zapasowe, aktualizacje, pipeline CVE
panel-administracyjny.md	Opis techniczny panelu `/admin`: architektura komponentów, endpointy API, zasady dostępności

Powiązane

- Model planów i dunningu
- Dokumentacja wdrożeniowa — operacje
- Interfejs webowy

Podręcznik administratora TestGEN

> **Wersja:** 1.0 · **Ostatnia aktualizacja:** 2026-09 · **Grupa docelowa:** Administrator platformy (rola Admin) oraz właściciel firmy (rola Owner)

Spis treści

1. Wprowadzenie
2. Zarządzanie tenantami (firmami)
3. Zarządzanie użytkownikami
4. Macierz uprawnień (RBAC)
5. Zarządzanie planami i rozliczeniami
6. Monitoring i logi
7. Konfiguracja trybu silnika (engine_mode)
8. Zarządzanie kluczami API
9. Dziennik audytu (Audit Trail)
10. Kopie zapasowe i przywracanie danych
11. Aktualizacje systemu
12. Pipeline CVE

---

1. Wprowadzenie

1.1. Cel dokumentu

Podręcznik opisuje codzienne operacje administracyjne platformy TestGEN — od zarządzania firmami i użytkownikami, przez monitoring, po kopie zapasowe i aktualizacje. Dokument przeznaczony jest dla dwóch ról:

- **Admin** — administrator platformy z dostępem do panelu `/admin`. Zarządza wszystkimi firmami, użytkownikami, konfiguracją globalną i dziennikiem audytu.
- **Owner** — właściciel firmy (tenanta). Zarządza użytkownikami w obrębie swojej firmy, planami, kluczami API i ustawieniami.

1.2. Panel administracyjny

Panel dostępny jest pod ścieżką `/admin` i wymaga roli **Admin** (flaga `is_admin` na koncie). Użytkownicy bez tej roli zostaną przekierowani na stronę 403.

Panel składa się z czterech głównych sekcji:

Sekcja	Ścieżka	Zakres
Użytkownicy	`/admin/users`	Lista kont, zaproszenia, blokady, zmiana roli, reset hasła
Firmy	`/admin/tenants`	Lista tenantów, plany, stan subskrypcji, szczegóły firmy
Dziennik audytu	`/admin/audit-log`	Operacje wrażliwe z filtrami: kto, co, kiedy, w której firmie
Konfiguracja	`/admin/config`	Parametry globalne: limity, ustawienia LLM, tryb konserwacji, flagi funkcji

Dodatkowo w module bezpieczeństwa dostępna jest sekcja **Pipeline CVE** (`/admin/cve-pipeline`) — patrz rozdział 12.

1.3. Konwencje dokumentu

- `monospace` — komendy, ścieżki, wartości konfiguracyjne
- **Uwaga** — informacja istotna dla poprawnego wykonania procedury
- **Ostrzeżenie** — operacja nieodwracalna lub wymagająca szczególnej ostrożności
- Zrzuty ekranu oznaczone `[Screenshot: opis]` — odpowiadają plikom w katalogu `img/`

---

2. Zarządzanie tenantami (firmami)

2.1. Czym jest tenant

Tenant (firma) to jednostka izolacji danych w TestGEN. Każdy tenant ma własną przestrzeń: użytkowników, projekty, analizy, pliki i wyniki. Izolacja realizowana jest na poziomie bazy danych za pomocą Row-Level Security (RLS) — kolumna `tenant_id` w każdej tabeli biznesowej.

2.2. Przeglądanie listy firm

Sekcja **Firmy** (`/admin/tenants`) wyświetla tabelę z kolumnami:

Kolumna	Opis
Nazwa	Nazwa firmy
Plan	Aktualny plan subskrypcji (Freemium / Basic / Premium)
Użytkownicy	Liczba aktywnych kont w firmie
Przestrzeń	Wykorzystane miejsce na dysku (pliki, dokumenty, raporty)
Projekty	Liczba projektów
Stan	Aktywna / Zablokowana
Data utworzenia	Kiedy firma została zarejestrowana

[Screenshot: ag-01-lista-firm.png]

Kliknięcie wiersza otwiera panel szczegółów firmy wraz z listą jej projektów.

2.3. Tworzenie tenanta

Nowa firma powstaje w momencie rejestracji pierwszego użytkownika (rola Owner) za pośrednictwem formularza rejestracyjnego. Administrator platformy może również utworzyć firmę ręcznie:

1. Przejdź do sekcji **Firmy** → przycisk **Nowa firma**
2. Wypełnij formularz:
   - **Nazwa firmy** (wymagane) — wyświetlana w interfejsie
   - **Slug** (wymagane) — unikalny identyfikator URL (np. `acme-corp`)
   - **NIP** (opcjonalne) — numer identyfikacji podatkowej
   - **Plan** — domyślnie `Freemium`
3. Kliknij **Utwórz**

Domyślne ustawienia nowej firmy:

- Plan: Freemium
- Stan: aktywna
- Tryb silnika: `native`
- Ustawienia dodatkowe: puste (JSONB `settings`)

2.4. Konfiguracja tenanta

Każda firma posiada konfigurację obejmującą:

- **Plan subskrypcji** — Freemium / Basic / Premium (patrz rozdział 5)
- **Limity** — zależne od planu (analiz/miesiąc, test case'ów/miesiąc, przestrzeń dyskowa, pliki na analizę)
- **Tryb silnika** — `native` / `llm` / `hybrid` (patrz rozdział 7)
- **Ustawienia dodatkowe** — przechowywane w polu JSONB `settings`

2.5. Limity per plan

Zasób	Freemium	Basic (30 PLN/mies.)	Premium (50 PLN/mies.)
Analizy / miesiąc	10	50	bez limitu
Test case'y / miesiąc	50	250	bez limitu
Przestrzeń dyskowa	0,5 GB	5 GB	10 GB
Pliki na analizę	5	25	50
Limit API (żądań/min)	100	100	1 000
Projekty	bez limitu	bez limitu	bez limitu

Przekroczenie limitu analiz lub test case'ów skutkuje odpowiedzią HTTP 429 (Too Many Requests). Przekroczenie limitu przestrzeni blokuje przesyłanie nowych plików.

2.6. Blokada i odblokowanie firmy

Blokada firmy odcina wszystkich jej użytkowników od platformy — nie mogą się logować ani korzystać z API. Dane firmy pozostają nienaruszone.

Procedura blokady:

1. Przejdź do sekcji **Firmy** → kliknij firmę
2. Przycisk **Zablokuj firmę** → potwierdź w oknie dialogowym
3. Stan zmienia się na „Zablokowana" — operacja ląduje w dzienniku audytu

Odblokowanie przebiega analogicznie — przycisk **Odblokuj firmę**.

> **Uwaga:** Blokada firmy to operacja natychmiastowa. Aktywne sesje użytkowników zostaną unieważnione przy następnym żądaniu (weryfikacja tokena JWT sprawdza stan firmy).

2.7. Archiwizacja tenanta

Archiwizacja to „miękkie" usunięcie firmy — firma staje się niewidoczna w interfejsie, ale jej dane pozostają w bazie przez okres retencji (domyślnie 90 dni).

Procedura:

1. **Zablokuj** firmę (patrz wyżej)
2. Przycisk **Archiwizuj** → potwierdź
3. Firma znika z domyślnej listy (filtr „Pokaż zarchiwizowane" pozwala ją zobaczyć)

Przywrócenie firmy z archiwum:

1. Włącz filtr **Pokaż zarchiwizowane**
2. Kliknij zarchiwizowaną firmę → przycisk **Przywróć**
3. Firma wraca do stanu „Zablokowana" — odblokuj ją ręcznie

> **Ostrzeżenie:** Po upływie okresu retencji (90 dni) dane zarchiwizowanej firmy mogą zostać trwale usunięte przez zadanie czyszczące.

2.8. Izolacja danych (Row-Level Security)

TestGEN wykorzystuje mechanizm Row-Level Security (RLS) PostgreSQL do izolacji danych pomiędzy firmami.

Jak to działa:

- Każda tabela biznesowa posiada kolumnę `tenant_id` (UUID)
- Na początku każdej transakcji ustawiany jest kontekst: `SET LOCAL app.current_tenant = '<tenant_id>'`
- Polityki RLS filtrują wiersze — użytkownik widzi wyłącznie dane swojej firmy
- Administrator platformy (`is_admin=True`) otrzymuje kontekst NIL UUID (`00000000-0000-0000-0000-000000000000`), co pomija filtr RLS

Weryfikacja izolacji — komendy SQL do kontroli:

```sql
-- Sprawdzenie, czy RLS jest aktywny na tabeli
SELECT tablename, rowsecurity
FROM pg_tables
WHERE schemaname = 'public' AND rowsecurity = true;

-- Sprawdzenie polityk RLS
SELECT tablename, policyname, cmd, qual
FROM pg_policies
WHERE schemaname = 'public';

-- Test izolacji — ustaw kontekst na firmę i sprawdź wyniki
SET LOCAL app.current_tenant = '<tenant_id>';
SELECT count(*) FROM projects;  -- widoczne tylko projekty firmy
```

> **Uwaga:** Nigdy nie wyłączaj RLS na tabelach produkcyjnych (`ALTER TABLE ... DISABLE ROW LEVEL SECURITY`). Nawet przy ręcznych zapytaniach diagnostycznych używaj kontekstu `app.current_tenant`.

---

3. Zarządzanie użytkownikami

3.1. Lista użytkowników

Sekcja **Użytkownicy** (`/admin/users`) wyświetla tabelę wszystkich kont platformy z kolumnami:

Kolumna	Opis
E-mail	Adres e-mail (login)
Imię i nazwisko	Nazwa wyświetlana
Rola	Rola w firmie (Owner / User) lub Admin platformy
Firma	Nazwa tenanta, do którego przypisany jest użytkownik
Stan	Aktywny / Zablokowany / Nieaktywny
Data utworzenia	Kiedy konto zostało założone
Ostatnie logowanie	Data i godzina ostatniej sesji

Kolumna	Opis
Akcje	Przyciski operacji

[Screenshot: ag-02-lista-uzytkownikow.png]

Tabela obsługuje stronicowanie serwerowe (25 rekordów na stronę) oraz filtrowanie klienckie po wyszukiwanej frazie, roli i stanie konta.

3.2. Role w systemie

TestGEN stosuje dwupoziomowy system ról:

Poziom platformy (flaga `is_admin` na koncie):

- **Admin** — pełny dostęp do panelu `/admin`, zarządzanie wszystkimi firmami i użytkownikami, pomija ograniczenia ról firmowych

Poziom firmy (pole `role` w tabeli `user_tenants`):

- **Owner** — właściciel firmy: zaprasza użytkowników, zmienia role, zarządza projektem, ustawieniami i rozliczeniami
- **User** — standardowy użytkownik: tworzy i uruchamia analizy, przegląda projekty, do których jest przypisany

> **Uwaga:** Role Analyst i Viewer są planowane — w obecnej wersji system rozróżnia Owner i User na poziomie firmy.

3.3. Zapraszanie użytkowników

Procedura (Owner lub Admin):

1. Przejdź do sekcji **Użytkownicy** → przycisk **Zaproś użytkownika**
2. Wypełnij formularz w oknie dialogowym:
   - **E-mail** (wymagane) — adres zapraszanego użytkownika
   - **Imię i nazwisko** (wymagane)
   - **Rola** — Owner lub User
   - **Firma** — firma, do której przypisany zostanie użytkownik (Admin widzi wszystkie firmy)
3. Kliknij **Zaproś**

Zaproszony użytkownik otrzyma e-mail z linkiem aktywacyjnym. Po kliknięciu w link ustawi hasło i opcjonalnie skonfiguruje MFA.

[Screenshot: ag-03-zapraszanie-uzytkownika.png]

3.4. Zmiana roli użytkownika

1. Na liście użytkowników kliknij przycisk **Edytuj** przy wybranym koncie

2. W oknie dialogowym zmień rolę (Owner ↔ User)
3. Potwierdź zmianę

Zmiana roli działa natychmiast — następne żądanie użytkownika będzie już weryfikowane z nową rolą (token JWT odświeża się automatycznie).

> **Ostrzeżenie:** Firma musi mieć przynajmniej jednego Ownera. System uniemożliwi zmianę roli ostatniego Ownera na User.

3.5. Blokowanie i odblokowywanie użytkowników

Blokada konta uniemożliwia logowanie i dostęp do API. Aktywne tokeny JWT zostają unieważnione.

Procedura:

1. Przy wybranym koncie kliknij **Zablokuj**
2. Potwierdź operację
3. Stan konta zmienia się na „Zablokowany"

Odblokowanie — przycisk **Odblokuj** → potwierdzenie. Użytkownik może ponownie się zalogować.

Każda operacja blokady/odblokowania jest zapisywana w dzienniku audytu.

3.6. Reset hasła

Administrator może wymusić reset hasła użytkownika:

1. Przy wybranym koncie kliknij **Reset hasła**
2. System wyśle e-mail z jednorazowym linkiem do ustawienia nowego hasła
3. Link jest ważny 24 godziny

Użytkownik musi ustawić hasło spełniające wymagania bezpieczeństwa:

- Minimum 12 znaków
- Przynajmniej jedna wielka litera, jedna mała, jedna cyfra i jeden znak specjalny
- Hasło jest haszowane algorytmem Argon2id

3.7. MFA (uwierzytelnianie wieloskładnikowe)

TestGEN obsługuje TOTP (Time-based One-Time Password) jako drugi składnik uwierzytelniania.

Wymuszenie MFA per firma: Owner firmy może włączyć obowiązkowe MFA dla wszystkich użytkowników w ustawieniach firmy. Po włączeniu użytkownicy bez skonfigurowanego TOTP zostaną poproszeni o jego aktywację przy następnym logowaniu.

Reset MFA (Admin): Jeśli użytkownik utracił dostęp do aplikacji uwierzytelniającej:

1. Przy wybranym koncie kliknij **Reset MFA**
2. Potwierdź operację
3. Wymóg drugiego składnika zostaje zdjęty
4. Użytkownik skonfiguruje MFA ponownie przy następnym logowaniu (jeśli jest wymuszone)

> **Uwaga:** Reset MFA to operacja wrażliwa — przed wykonaniem zweryfikuj tożsamość użytkownika innym kanałem (telefon, spotkanie). Każdy reset jest audytowany.

3.8. Usuwanie użytkowników

Usunięcie konta jest „miękkie" — ustawia pole `deleted_at` na bieżącą datę. Użytkownik nie może się logować, ale jego dane pozostają w systemie na potrzeby audytu.

1. Przy wybranym koncie kliknij **Usuń**
2. Potwierdź operację

> **Ostrzeżenie:** Nie można usunąć ostatniego Ownera firmy ani konta administratora platformy.

---

4. Macierz uprawnień (RBAC)

4.1. Uprawnienia per rola i moduł

Poniższa tabela przedstawia uprawnienia każdej roli w poszczególnych modułach systemu.

Moduł	Admin (platforma)	Owner (firma)	User (firma)
Panel admina	Pełny dostęp	Brak	Brak
Zarządzanie firmą	Wszystkie firmy (C/R/U/D)	Własna firma (R/U)	Brak
Użytkownicy	Wszyscy (C/R/U/D)	W swojej firmie (C/R/U/D)	Profil własny (R/U)
Projekty	Wszystkie (R)	W swojej firmie (C/R/U/D)	Przypisane (C/R/U)
Analiza kodu	Wszystkie (R)	W swojej firmie (C/R)	Przypisane projekty (C/R)

Moduł	Admin (platforma)	Owner (firma)	User (firma)
Generowanie testów	Wszystkie (R)	W swojej firmie (C/R/U)	Przypisane projekty (C/R/U)
Analiza bezpieczeństwa	Wszystkie (R)	W swojej firmie (C/R)	Przypisane projekty (C/R)
Eksport raportów	Wszystkie (R)	W swojej firmie (C/R)	Przypisane projekty (C/R)
Rozliczenia	Podgląd wszystkich	Zarządzanie (C/R/U)	Brak
Ustawienia firmy	Wszystkie (R/U)	Własna firma (R/U)	Brak
Klucze API	Wszystkie (R/U/D)	W swojej firmie (C/R/U/D)	Brak
Dziennik audytu	Cała platforma (R)	Własna firma (R)	Brak

Legenda: **C** — tworzenie, **R** — odczyt, **U** — edycja, **D** — usuwanie.

4.2. Bramki funkcji (Feature Gating)

Niezależnie od roli, dostęp do niektórych modułów zależy od planu subskrypcji:

Moduł	Freemium	Basic	Premium
Analiza kodu	✓	✓	✓
Generowanie testów	✓	✓	✓
Dokumentacja	✗	✓	✓
Diagramy UML	✗	✓	✓
Testy GUI	✗	✓	✓
Testy integracyjne	✗	✓	✓
Generator CI/CD	✗	✓	✓
Analiza bezpieczeństwa	✗	✗	✓
Rekomendacje bezpieczeństwa	✗	✗	✓
Spójność kodu z dokumentacją	✗	✗	✓
Luki funkcjonalne (Gap Analysis)	✗	✗	✓

Zablokowane moduły wyświetlają ikonę kłódki w interfejsie. Próba wywołania zablokowanego endpointu zwraca HTTP 402 (Payment Required).

4.3. Weryfikacja uprawnień — jak to działa

1. **Żądanie HTTP** trafia do backendu z tokenem JWT
2. **Guard routera** (`require_role()`) sprawdza:
   - Czy `is_admin=True` → jeśli tak, przepuszcza zawsze
   - Czy rola z tokena (`owner` / `user`) znajduje się na liście dozwolonych ról
3. **RLS PostgreSQL** filtruje dane po `tenant_id` z kontekstu sesji

4. **Bramka funkcji** (`FeatureGatingService`) weryfikuje, czy plan firmy obejmuje żądany moduł
5. **Limity kwot** (`QuotaService`) sprawdzają, czy firma nie przekroczyła limitów miesiąca

---

5. Zarządzanie planami i rozliczeniami

5.1. Plany subskrypcji

Cecha	Freemium	Basic	Premium
Cena	0 PLN	30 PLN / mies.	50 PLN / mies.
Analizy / miesiąc	10	50	bez limitu
Test case'y / miesiąc	50	250	bez limitu
Przestrzeń dyskowa	0,5 GB	5 GB	10 GB
Pliki na analizę	5	25	50
Limit API (żądań/min)	100	100	1 000
Moduły	Podstawowe	Rozszerzone	Pełne (incl. bezpieczeństwo)

> **Uwaga:** Ceny konfigurowane są zmiennymi środowiskowymi: `BILLING_BASIC_MONTHLY_PRICE` i `BILLING_PREMIUM_MONTHLY_PRICE`.

5.2. Proces zakupu subskrypcji

1. **Owner** firmy przechodzi do **Ustawienia** → **Plan i rozliczenia** → **Zmień plan**
2. Wybiera plan docelowy (Basic lub Premium)
3. System tworzy transakcję płatności i przekierowuje do bramki **tpay**
4. Użytkownik płaci za pomocą BLIK, karty płatniczej lub przelewu bankowego
5. Po potwierdzeniu płatności (webhook tpay → backend):
   - Plan zostaje aktywowany natychmiast
   - System generuje fakturę VAT (PDF) i zapisuje ją w magazynie plików
   - Faktura dostępna jest w sekcji **Rozliczenia** → **Historia faktur**

5.3. Cykl rozliczeniowy

- Okres rozliczeniowy: miesięczny (od daty aktywacji)
- Automatyczne odnowienie: system obciąża zapisany token płatniczy (BLIK alias lub karta)
- Zadanie odnawiające: Celery Beat uruchamia je codziennie o 03:30
- Migawka użycia: codzienny snapshot o 00:00 rejestruje zużycie zasobów per firma

5.4. Zmiana planu (upgrade / downgrade)

Upgrade (np. Freemium → Basic lub Basic → Premium):

- Nowy plan aktywowany natychmiast po płatności
- Limity zwiększają się od razu
- Naliczenie proporcjonalne za pozostałe dni bieżącego okresu

Downgrade (np. Premium → Basic lub Basic → Freemium):

- Obowiązuje od następnego okresu rozliczeniowego
- Dane powyżej nowych limitów **nie** są usuwane, ale firma nie może dodawać nowych zasobów powyżej limitu
- Zablokowane moduły stają się niedostępne (ikona kłódki)

5.5. Dunning (obsługa nieudanych płatności)

Gdy automatyczne odnowienie się nie powiedzie:

1. **Dzień 0** — płatność odrzucona → status firmy zmienia się na `grace` (okres łaski)
2. **Dni 1–7** — firma działa normalnie, system podejmuje ponowne próby obciążenia
3. **Dzień 7** — jeśli płatność nadal nieopłacona → automatyczne obniżenie planu do Freemium
4. Dane firmy **nie są usuwane** — jedynie ograniczony zostaje dostęp do modułów

> **Uwaga:** Administrator platformy widzi status `grace` w kolumnie „Stan" na liście firm. Firma w okresie łaski jest oznaczona kolorem ostrzegawczym.

5.6. Replay webhooków płatności

Jeśli webhook tpay nie dotarł lub przetwarzanie się nie powiodło, administrator może odtworzyć zdarzenie:

1. Przejdź do panelu admina → endpunkt API: `POST /api/v1/admin/billing/webhooks/{event_uid}/replay`
2. System ponownie przetworzy zapisane dane webhooka (bez weryfikacji podpisu — zaufane powtórzenie)
3. Operacja jest idempotentna — powtórne wywołanie nie spowoduje podwójnego naliczenia
4. Odrzucone zdarzenia zwrócą HTTP 409 (Conflict)

Szczegóły: ../architecture/billing/04-webhooki.md

---

6. Monitoring i logi

6.1. Architektura monitoringu

TestGEN wykorzystuje stos obserwacyjny:

Komponent	Rola
Prometheus	Zbieranie metryk (scraping co 15 s)
Grafana	Wizualizacja metryk i logów (dashboardy)
Loki	Agregacja logów aplikacji i infrastruktury
Promtail	Kolektor logów — przesyła logi do Loki
Alertmanager	Routing i eskalacja alertów

6.2. Dostęp do Grafany

- **URL:** `https://<domena>:3000` (domyślnie port 3000; w K8s — przez Ingress)
- **Logowanie:** konto administratora Grafany (ustawiane w konfiguracji wdrożeniowej)
- **Źródła danych:** Prometheus (metryki) i Loki (logi) — skonfigurowane automatycznie

6.3. Dashboardy administracyjne

TestGEN dostarcza gotowy dashboard Grafany (`testgen-overview`) z następującymi panelami:

Przegląd systemu:

Panel	Metryka	Próg ostrzegawczy	Próg krytyczny
Wykorzystanie CPU	`node_cpu_seconds_total`	70%	90%
Wykorzystanie pamięci	`node_memory_MemAvailable_bytes`	75%	90%
Wykorzystanie dysku	`node_filesystem_avail_bytes`	80%	95%

Metryki aplikacji:

Panel	Metryka	Opis
Żądania HTTP/s	`http_requests_total`	Częstotliwość żądań per kod statusu
Czas odpowiedzi P50/P95/P99	`http_request_duration_seconds_bucket`	Percentyle czasu odpowiedzi

Baza danych i kolejki:

Panel	Metryka	Opis
PostgreSQL — aktywne połączenia	`pg_stat_activity_count`	Ostrzeżenie: >150, krytyczny: >190
Redis — zużycie pamięci	`redis_memory_used_bytes`	Bieżące zużycie RAM przez Redis
MinIO — wykorzystanie dysku	`minio_cluster_usage_total_bytes`	Zajęta przestrzeń obiektowa
Kolejki RabbitMQ	`rabbitmq_queue_messages`	Głębokość kolejek (ostrzeżenie: >500, kryt.: >2000)
Celery — zadania	`flower_active_tasks`, `flower_received_tasks`	Aktywne i odebrane zadania asynchroniczne

Import dashboardu: **Grafana UI** → **Import** → wskazanie pliku `grafana-dashboard.json` z katalogu `docs/final/deployment-guide/examples/`.

6.4. Zapytania Loki (LogQL)

Przykłady zapytań w Loki/Grafana Explore:

Filtrowanie logów po firmie:

```
{app="testgen-backend"} | json | tenant_id="<tenant_uuid>"
```

Wyszukiwanie błędów:

```
{app="testgen-backend"} | json | level="error"
```

Filtrowanie po identyfikatorze żądania:

```
{app="testgen-backend"} | json | request_id="<request_uuid>"
```

Filtrowanie po użytkowniku:

```
{app="testgen-backend"} | json | user_id="<user_uuid>"
```

Analiza częstotliwości błędów (okno 5 min):

```
sum(rate({app="testgen-backend"} | json | level="error" [5m]))
```

Histogram czasów odpowiedzi:

```
{app="testgen-backend"} | json | unwrap duration | __error__="" |
quantile_over_time(0.95, [5m])
```

6.5. Alerty

System alertów skonfigurowany w Prometheusie (reguły w `prometheus-rules.yml`):

Alerty systemowe:

Alert	Warunek	Ważność
Dysk > 85%	`node_filesystem_avail_bytes / node_filesystem_size_bytes < 0.15`	Ostrzeżenie
Dysk > 95%	`node_filesystem_avail_bytes / node_filesystem_size_bytes < 0.05`	Krytyczny
CPU > 80%	`avg(rate(node_cpu_seconds_total{mode="idle"}[5m])) < 0.20`	Ostrzeżenie
CPU > 95%	`avg(rate(node_cpu_seconds_total{mode="idle"}[5m])) < 0.05`	Krytyczny
Pamięć > 85%	`node_memory_MemAvailable_bytes / node_memory_MemTotal_bytes < 0.15`	Ostrzeżenie

Alerty aplikacyjne:

Alert	Warunek	Ważność
Współczynnik błędów > 5%	`rate(http_requests_total{status=~"5.."}[5m]) / rate(http_requests_total[5m]) > 0.05`	Ostrzeżenie
Współczynnik błędów > 10%	`rate(http_requests_total{status=~"5.."}[5m]) / rate(http_requests_total[5m]) > 0.10`	Krytyczny
Głębokość kolejki > 1000	`rabbitmq_queue_messages > 1000`	Ostrzeżenie
Celery — zadania zaległe > 100	`flower_pending_tasks > 100`	Ostrzeżenie

Kanały powiadomień (konfiguracja w Alertmanagerze):

- E-mail — domyślny kanał
- Slack — webhook do kanału `#alerts`
- PagerDuty — dla alertów krytycznych (opcjonalnie)

Eskalacja: alerty ostrzegawcze czekają 5 minut przed wysłaniem; alerty krytyczne są wysyłane natychmiast. Powtórzenie co 30 minut do rozwiązania.

---

7. Konfiguracja trybu silnika (engine_mode)

7.1. Tryby przetwarzania

TestGEN oferuje trzy tryby generowania wyników analiz:

Tryb	Opis	Szybkość	Koszt	Jakość
native	Szablony deterministyczne + reguły statyczne	Najszybszy	Najniższy (0 PLN/analiza)	Dobra — powtarzalna, przewidywalna
llm	Generowanie za pomocą modelu językowego (LLM)	Wolniejszy	Najwyższy (~0,10–0,50 PLN/analiza)	Najlepsza — semantyczna, kontekstowa
hybrid	Najpierw native, potem LLM wzbogaca wyniki	Średni	Średni	Bardzo dobra — łączy zalety obu

7.2. Konfiguracja domyślnego trybu

Na poziomie platformy (Admin):

1. Panel admina → **Konfiguracja** → sekcja **LLM**
2. Ustaw parametry:
   - **Dostawca** — `anthropic` lub `openai`
   - **Model** — np. `claude-sonnet-4-20250514`, `gpt-4o`
   - **Temperatura** — 0.0–1.0 (niższa = bardziej deterministyczny)
   - **Maksymalna liczba tokenów** — limit odpowiedzi
   - **Limit czasu** — timeout żądania do LLM (w sekundach)
3. Ustaw **limit kosztów LLM** w sekcji **Limity** (`llmCostLimitUsd`)

[Screenshot: ag-04-konfiguracja-llm.png]

Na poziomie firmy: Owner może wybrać domyślny tryb silnika w ustawieniach firmy. Administrator platformy może nadpisać ten wybór.

7.3. Wpływ na koszty

Estymacja kosztów za 100 analiz:

Tryb	Koszt estymowany	Uwagi
native	0 PLN	Brak wywołań API LLM
hybrid	10–30 PLN	Zależy od złożoności kodu i modelu
llm	20–50 PLN	Każda analiza wywołuje LLM

> **Uwaga:** Koszty zależą od wybranego modelu, długości analizowanego kodu i parametrów generowania. Limit `llmCostLimitUsd` w konfiguracji platformy chroni przed niekontrolowanym wzrostem wydatków.

7.4. Rekomendacje

Scenariusz	Rekomendowany tryb
Duża liczba analiz, ograniczony budżet	`native`

Scenariusz	Rekomendowany tryb
Prototypowanie, małe zespoły	`hybrid`
Najwyższa jakość, krytyczny projekt	`llm`
Nowa firma (Freemium)	`native` (domyślny)
Firma Premium z dużą liczbą deweloperów	`hybrid`

---

8. Zarządzanie kluczami API

8.1. Czym są klucze API

Klucze API pozwalają na programistyczny dostęp do TestGEN bez logowania przez przeglądarkę. Każdy klucz ma:

- **Zakres** (scope) — jakie operacje są dozwolone
- **Datę wygaśnięcia** — po jej upływie klucz jest automatycznie unieważniany
- **Limit żądań** — zależny od planu firmy

8.2. Tworzenie klucza

Procedura (Owner lub Admin):

1. Przejdź do **Ustawienia** → **Klucze API** → przycisk **Nowy klucz**
2. Wypełnij formularz:
   - **Nazwa** — opis przeznaczenia klucza (np. „CI/CD Pipeline", „Monitoring")
   - **Zakres** — wybór uprawnień: `read`, `write`, `admin`
   - **Data wygaśnięcia** — domyślnie 90 dni, maksymalnie 365 dni
3. Kliknij **Utwórz**
4. **Skopiuj klucz** — wyświetlany jest tylko raz! System przechowuje jedynie skrót (hash)

[Screenshot: ag-05-tworzenie-klucza-api.png]

8.3. Limity żądań (Rate Limiting)

Plan	Żądań / minutę	Burst	Dzienny limit
Freemium	100	20	5 000
Basic	100	50	50 000
Premium	1 000	200	500 000

Przekroczenie limitu zwraca HTTP 429 (Too Many Requests) z nagłówkiem `Retry-After`.

8.4. Rotacja kluczy

Dobre praktyki:

- Rotuj klucze **co kwartał** (90 dni)
- Procedura bezpiecznej rotacji:
  1. Utwórz nowy klucz z takim samym zakresem
  2. Zaktualizuj klucz w systemach zewnętrznych (CI/CD, skrypty)
  3. Zweryfikuj, że systemy korzystają z nowego klucza
  4. Unieważnij stary klucz

8.5. Unieważnianie klucza (Revoke)

1. Przejdź do **Ustawienia** → **Klucze API**
2. Przy wybranym kluczu kliknij **Unieważnij**
3. Potwierdź operację

Unieważnienie jest natychmiastowe — kolejne żądania z tym kluczem otrzymają HTTP 401. Operacja jest zapisywana w dzienniku audytu.

8.6. Dobre praktyki

- **Zasada minimalnych uprawnień** — nadawaj najwęższy możliwy zakres
- **Rotacja kwartalna** — automatyczne przypomnienia w systemie
- **Monitorowanie użycia** — śledź liczbę żądań per klucz w dzienniku audytu
- **Osobne klucze per system** — nie współdziel klucza między CI/CD a monitoringiem
- **Nigdy nie umieszczaj kluczy w kodzie źródłowym** — używaj zmiennych środowiskowych lub menedżera sekretów

---

9. Dziennik audytu (Audit Trail)

9.1. Czym jest dziennik audytu

Dziennik audytu rejestruje wszystkie operacje wrażliwe na platformie. Każdy wpis zawiera:

Pole	Opis
Data i godzina	Znacznik czasu operacji (UTC)
Użytkownik	Kto wykonał operację (e-mail, ID)
Firma	W kontekście której firmy (tenant_id)
Akcja	Typ operacji (np. `user.block`, `tenant.update`, `analysis.create`)
Typ zasobu	Czego dotyczy (np. `user`, `tenant`, `project`, `analysis`)
ID zasobu	Identyfikator obiektu
Szczegóły	Dodatkowe informacje (JSON)

Pole	Opis
Zmiany	Jakie pola zostały zmienione (JSON: stara → nowa wartość)
Adres IP	Z jakiego adresu wykonano operację

9.2. Przeglądanie logów

Sekcja **Dziennik audytu** (`/admin/audit-log`) wyświetla tabelę z filtrami:

[Screenshot: ag-06-dziennik-audytu.png]

Dostępne filtry:

Filtr	Opis
Zakres dat	Od — Do (wybór z kalendarza)
Użytkownik	ID lub wyszukiwanie po e-mailu
Firma	ID tenanta lub nazwa
Typ akcji	Wybór z listy (lista pobierana dynamicznie z endpointu `/admin/audit-logs/actions`)
Typ zasobu	Filtrowanie po rodzaju obiektu

Tabela obsługuje stronicowanie (25/50/100 rekordów na stronę).

9.3. Typy audytowanych zdarzeń

Kategoria	Przykłady zdarzeń
Uwierzytelnianie	`auth.login` , `auth.logout` , `auth.mfa_setup` , `auth.mfa_reset` , `auth.password_reset`
Użytkownicy	`user.create` , `user.invite` , `user.block` , `user.unblock` , `user.delete` , `user.role_change`
Firmy	`tenant.create` , `tenant.update` , `tenant.block` , `tenant.archive` , `tenant.restore`
Projekty	`project.create` , `project.update` , `project.delete`
Analizy	`analysis.create` , `analysis.start` , `analysis.complete` , `analysis.fail`
Bezpieczeństwo	`security_scan.start` , `security_scan.complete` , `cve_pipeline.trigger`
Eksport	`export.pdf` , `export.html` , `export.excel` , `export.csv` , `export.json`
Rozliczenia	`billing.checkout` , `billing.payment_success` , `billing.payment_failed` , `billing.plan_change` , `billing.webhook_replay`
Konfiguracja	`config.update` , `api_key.create` , `api_key.revoke`

9.4. Eksport logów audytu

Logi audytu można wyeksportować w dwóch formatach:

- **CSV** — arkusz kalkulacyjny, wygodny do dalszej analizy
- **JSON** — format strukturalny, przydatny do automatyzacji

Procedura:

1. Ustaw filtry (zakres dat, firma, typ akcji — opcjonalnie)
2. Kliknij **Eksportuj** → wybierz format
3. Plik zostanie pobrany na dysk

9.5. Retencja

- Domyślny okres retencji: **90 dni**
- Po upływie 90 dni wpisy są automatycznie archiwizowane
- Zarchiwizowane wpisy pozostają w bazie, ale nie są wyświetlane w interfejsie
- Na potrzeby audytu zewnętrznego: wyeksportuj logi przed upływem okresu retencji

> **Uwaga:** Wpisy audytu dotyczące firm zachowują `tenant_id` nawet po usunięciu firmy — pozwala to odtworzyć historię operacji.

---

10. Kopie zapasowe i przywracanie danych

10.1. Perspektywa administratora

Ta sekcja opisuje kopie zapasowe z perspektywy administratora platformy. Szczegóły techniczne (komendy, skrypty, konfiguracja) znajdują się w Dokumentacji wdrożeniowej — operacje.

10.2. Typy kopii zapasowych

Typ	Opis	Częstotliwość	RPO
Pełna (pg_dump)	Kompletna kopia bazy danych PostgreSQL	Codziennie o 02:00	< 24 h
Ciągła (WAL)	Archiwizacja logów transakcji PostgreSQL	Ciągła	< 1 h
Redis (RDB)	Migawka cache'u i sesji	Co 6 godzin	< 6 h
MinIO (mc mirror)	Kopia plików użytkowników i raportów	Codziennie o 03:00	< 24 h
Konfiguracja	Pliki `.env`, certyfikaty, klucze JWT	Przy każdej zmianie	—

> **RPO** (Recovery Point Objective) — maksymalny akceptowalny czas utraty danych. Wymaganie systemu: RPO < 1 godzina (NFR32), co zapewnia archiwizacja WAL.

10.3. Weryfikacja kopii zapasowych

Regularne zadania weryfikacyjne:

1. **Codzienny raport** — skrypt backup generuje raport o powodzeniu (plik log + e-mail)
2. **Cotygodniowy test restore** — przywrócenie kopii na środowisku testowym i weryfikacja spójności
3. **Checksum** — każda kopia zawiera sumę kontrolną SHA-256
4. **Monitoring** — alert Prometheus przy braku świeżej kopii (starsze niż 25 godzin)

10.4. Przywracanie danych per firma

W przypadku uszkodzenia danych pojedynczej firmy można wykonać izolowany restore:

1. Przywróć pełną kopię bazy na tymczasowy serwer PostgreSQL
2. Wyeksportuj dane wyłącznie danej firmy:

```
-- Na tymczasowym serwerze
SET LOCAL app.current_tenant = '<tenant_id>';
COPY (SELECT * FROM projects) TO '/tmp/projects.csv' CSV HEADER;
COPY (SELECT * FROM analyses) TO '/tmp/analyses.csv' CSV HEADER;
-- ... powtórz dla każdej tabeli
```

3. Zaimportuj dane na serwer produkcyjny
4. Zweryfikuj integralność — policz rekordy, sprawdź relacje FK

> **Ostrzeżenie:** Przywracanie per firma to operacja zaawansowana. Koordynuj ją z zespołem DevOps. W razie wątpliwości — przywróć pełną kopię.

10.5. Inicjowanie kopii zapasowej z panelu

Administrator może wymusić natychmiastową kopię zapasową:

1. Panel admina → **Konfiguracja** → sekcja **Konserwacja**
2. Opcja **Wykonaj kopię zapasową teraz** (wywołuje zadanie Celery)
3. Status kopii widoczny w logach systemowych (Grafana/Loki)

---

11. Aktualizacje systemu

11.1. Procedura z perspektywy administratora

Aktualizacja systemu to operacja koordynowana pomiędzy administratorem platformy (komunikacja z użytkownikami) a zespołem DevOps (wdrożenie techniczne).

11.2. Przed aktualizacją

1. **Sprawdź informacje o wydaniu** — przeczytaj release notes nowej wersji (patrz Release notes i changelog)
2. **Zaplanuj okno konserwacji** — wybierz termin poza godzinami szczytu (rekomendacja: 02:00–06:00)
3. **Powiadom użytkowników:**
   - Włącz **tryb konserwacji** w panelu admina → **Konfiguracja** → **Konserwacja**:
     - Przełącznik **Włączony** = tak
     - **Komunikat** — treść wyświetlana użytkownikom (np. „Planowana konserwacja 15.10.2026 02:00–04:00")
   - System wyświetli baner ostrzegawczy na każdej stronie
   - Wyślij powiadomienie e-mail (opcjonalnie)

[Screenshot: ag-07-tryb-konserwacji.png]

11.3. Podczas aktualizacji

Operacje techniczne wykonuje zespół DevOps:

1. Kopia zapasowa (automatyczna lub wymuszona)
2. Wdrożenie nowej wersji (rolling update / blue-green)
3. Migracja bazy danych (Alembic)
4. Weryfikacja (health check)

Szczegóły techniczne: Dokumentacja wdrożeniowa — operacje

11.4. Po aktualizacji

1. **Weryfikacja** — smoke test:
   - Logowanie (z MFA)
   - Tworzenie projektu
   - Uruchomienie analizy
   - Podgląd dashboardu
   - Sprawdzenie logów w Grafanie — brak nowych błędów
2. **Wyłącz tryb konserwacji** — panel admina → **Konfiguracja** → **Konserwacja** → przełącznik **Włączony** = nie
3. **Powiadom użytkowników** o zakończeniu prac

11.5. Wycofanie aktualizacji (rollback)

Jeśli po aktualizacji wykryto problemy:

1. Poinformuj zespół DevOps
2. DevOps wykonuje rollback (procedura opisana w dokumentacji wdrożeniowej)
3. Zweryfikuj przywrócenie funkcjonalności
4. Wyłącz tryb konserwacji
5. Powiadom użytkowników

> **Uwaga:** Migracje bazy danych (Alembic) mogą być nieodwracalne. W takim przypadku konieczne jest przywrócenie bazy z kopii zapasowej.

---

12. Pipeline CVE

12.1. Czym jest pipeline CVE

Pipeline CVE to mechanizm automatycznej aktualizacji bazy znanych podatności (CVE — Common Vulnerabilities and Exposures) używanej przez moduł analizy bezpieczeństwa. Aktualizacja pobiera dane z zewnętrznych źródeł (NVD, GitHub Advisory, OSV) i integruje je z bazą reguł skanowania.

12.2. Panel pipeline'u CVE

Sekcja dostępna pod `/admin/cve-pipeline` zawiera:

[Screenshot: ag-08-cve-pipeline.png]

- **Status ostatniego uruchomienia** — data, czas trwania, liczba nowych/zaktualizowanych wpisów, błędy
- **Źródła danych** — zestawienie źródeł z liczbą pobranych rekordów
- **Historia uruchomień** — tabela z ostatnimi 100 uruchomieniami pipeline'u
- **Przycisk „Uruchom aktualizację"** — ręczne wyzwolenie aktualizacji bazy CVE

12.3. Ręczne wyzwolenie aktualizacji

Kiedy warto:

- Po opublikowaniu krytycznej podatności 0-day
- Po dłuższej przerwie w automatycznych aktualizacjach
- Przed uruchomieniem skanowania bezpieczeństwa ważnego projektu

Procedura:

1. Przejdź do `/admin/cve-pipeline`

2. Kliknij **Uruchom aktualizację**
3. System zakolejkuje zadanie Celery (odpowiedź HTTP 202)
4. Obserwuj postęp w historii uruchomień — odśwież stronę po kilku minutach

12.4. Powiązana dokumentacja

- Szczegóły działania pipeline'u: ../ai-modules/bezpieczenstwo/04-pipeline-cve/01-zrodla-danych.md

---

Dodatek A: Szybka ściągawka administratora

Operacja	Ścieżka / Komenda
Zablokuj użytkownika	`/admin/users` → Zablokuj
Reset MFA	`/admin/users` → Reset MFA
Zablokuj firmę	`/admin/tenants` → firma → Zablokuj firmę
Wymuś kopię zapasową	`/admin/config` → Konserwacja → Wykonaj kopię
Włącz tryb konserwacji	`/admin/config` → Konserwacja → Włączony = tak
Odtwórz webhook	`POST /api/v1/admin/billing/webhooks/{uid}/replay`
Zaktualizuj bazę CVE	`/admin/cve-pipeline` → Uruchom aktualizację
Sprawdź logi błędów	Grafana → Explore → `{app="testgen-backend"} | json | level="error"`
Sprawdź wykorzystanie CPU	Grafana → Dashboard „TestGEN — przegląd produkcyjny"
Eksportuj dziennik audytu	`/admin/audit-log` → filtry → Eksportuj

Dodatek B: Słownik terminów

Termin	Definicja
Tenant	Firma (organizacja) w systemie; jednostka izolacji danych
RLS	Row-Level Security — mechanizm PostgreSQL filtrujący dane per tenant
RBAC	Role-Based Access Control — kontrola dostępu oparta na rolach
MFA / TOTP	Uwierzytelnianie wieloskładnikowe / jednorazowy kod czasowy
Dunning	Proces obsługi nieudanych płatności
RPO	Recovery Point Objective — maksymalny akceptowalny czas utraty danych
RTO	Recovery Time Objective — maksymalny czas przywracania systemu
CVE	Common Vulnerabilities and Exposures — baza znanych podatności
SAST	Static Application Security Testing — statyczne skanowanie bezpieczeństwa kodu

Termin	Definicja
WAL	Write-Ahead Log — dziennik transakcji PostgreSQL (ciągła replikacja)
Feature Gating	Mechanizm blokowania modułów niedostępnych w danym planie

Panel administracyjny

> Panel administratora platformy TestGEN (Epic 6, Story 6-15) — scalone: architektura panelu + przewodnik użytkownika. Implementacja: `frontend/src/app/features/admin/` (+ backend `backend/app/api/routes/admin.py`, `admin_cve.py`).

1. Dostęp i architektura

Trasa `/admin` — lazy loading, ochrona `role.guard` rolą **Admin** (platformowy; poza hierarchią tenanta). Użytkownicy bez roli trafiają na `/403`. Panel obsługuje całą platformę, nie pojedynczy tenant.

Sekcje (komponenty `features/admin/`):

Komponent	Zakres
`user-management` (+ `user-dialog`)	użytkownicy platformy: lista, wyszukiwanie, blokada/odblokowanie, zmiana roli, reset MFA
`tenant-management`	tenanci: lista, stan subskrypcji (plan), blokada tenanta
`audit-log`	dziennik operacji wrażliwych (audyt backendowy) z filtrami: kto, co, kiedy, tenant
`platform-config`	ustawienia platformy (parametry globalne)
`cve-pipeline` (`/admin/cve-pipeline`)	pipeline CVE modułu bezpieczeństwa (E4): status aktualizacji bazy CVE, historia uruchomień, wymuszenie rescanu

2. Użytkownicy

Sekcja **Użytkownicy**: lista wszystkich kont platformy z wyszukiwaniem.

- **Blokada/odblokowanie konta** — zablokowany użytkownik nie loguje się,
- **zmiana roli** — User/Owner/Admin (dialog z potwierdzeniem),
- **reset MFA** — zdjęcie wymogu drugiego składnika (np. utrata telefonu); użytkownik konfiguruje MFA ponownie przy logowaniu,
- każda operacja zapisuje się w audycie.

3. Firmy (tenanci)

Sekcja **Firmy**: lista tenantów z planem subskrypcji i stanem. Blokada tenanta odcina jego użytkowników od platformy (dane pozostają). Tu widać też plan i status subskrypcji (aktywna/grace) — szczegóły modelu planów: ../architecture/billing/.

4. Dziennik audytu

Sekcja **Audyt**: operacje wrażliwe z całej platformy — kto, co, kiedy, w którym tenancie. Filtry po użytkowniku, typie operacji i zakresie dat. Audyt obejmuje także działania administratorów (własne operacje widać na liście) oraz przetwarzanie webhooków płatności.

5. Konfiguracja platformy

Sekcja **Konfiguracja**: parametry globalne platformy. Zmiany działają natychmiast i są audytowane; ustawienia wrażliwe (np. sekrety providerów) nie są edytowalne z panelu — wyłącznie przez env/infrastrukturę.

6. Pipeline CVE

Sekcja **CVE** (`/admin/cve-pipeline`, moduł bezpieczeństwa): stan bazy CVE, harmonogram i historia aktualizacji, wymuszenie ponownego skanu po odświeżeniu reguł. Szczegóły działania pipeline'u: ../ai-modules/bezpieczenstwo/04-pipeline-cve/01-zrodla-danych.md.

7. Zdrowie webhooków płatności

Operacje bilingowe admina (health webhooków tpay, replay notyfikacji) opisane w ../architecture/billing/04-webhooki.md.

8. Zasady i dostępność

- Każda operacja administracyjna ląduje w audycie (sekcja 4),
- zmiany ról/blokad działają natychmiast; blokada tenanta = odcięcie jego użytkowników od API (RLS + guards),
- panel podlega tym samym wymogom WCAG 2.1 AA co cała aplikacja — potwierdzone dedykowanym specem `admin.a11y.spec.ts` (struktura nagłówków, etykiety tabel, komunikaty operacji w live region).